

Task 1: Security Assessment – Findings

User Management Web Application

Objective

The objective of this task was to identify security vulnerabilities in a User Management Web Application using manual testing and automated tools.

Vulnerabilities Identified

1. Brute Force Vulnerability

The application allows unlimited login attempts without any restriction.

Impact:

This makes the system vulnerable to brute-force attacks where attackers can repeatedly try different password combinations.

2. Missing Content Security Policy (CSP)

The application does not implement a Content Security Policy header.

Impact:

This increases the risk of Cross-Site Scripting (XSS) attacks.

3. Missing X-Frame-Options Header

The application does not restrict embedding within iframes.

Impact:

This exposes users to clickjacking attacks.

4. Missing X-Content-Type-Options Header

The application does not define content type protection.

Impact:

This may allow MIME-type sniffing attacks.

5. Information Disclosure (X-Powered-By Header)

The server reveals technology information through headers.

Impact:

Attackers can use this information to target specific vulnerabilities.

6. Cross-Origin Resource Sharing (CORS) Misconfiguration

The application has improper CORS configuration.

Impact:

Unauthorized domains may access sensitive data.

Areas of Improvement

- Implement login attempt limits to prevent brute-force attacks
- Add security headers (CSP, X-Frame-Options, X-Content-Type-Options)
- Disable X-Powered-By header to prevent information disclosure
- Configure strict CORS policies
- Improve authentication (e.g., session timeout, MFA)
- Perform regular security testing and vulnerability scans

Summary

The assessment identified multiple security misconfigurations and a lack of brute-force protection. While the application has basic input validation and authentication mechanisms, additional security measures are required to strengthen overall protection.